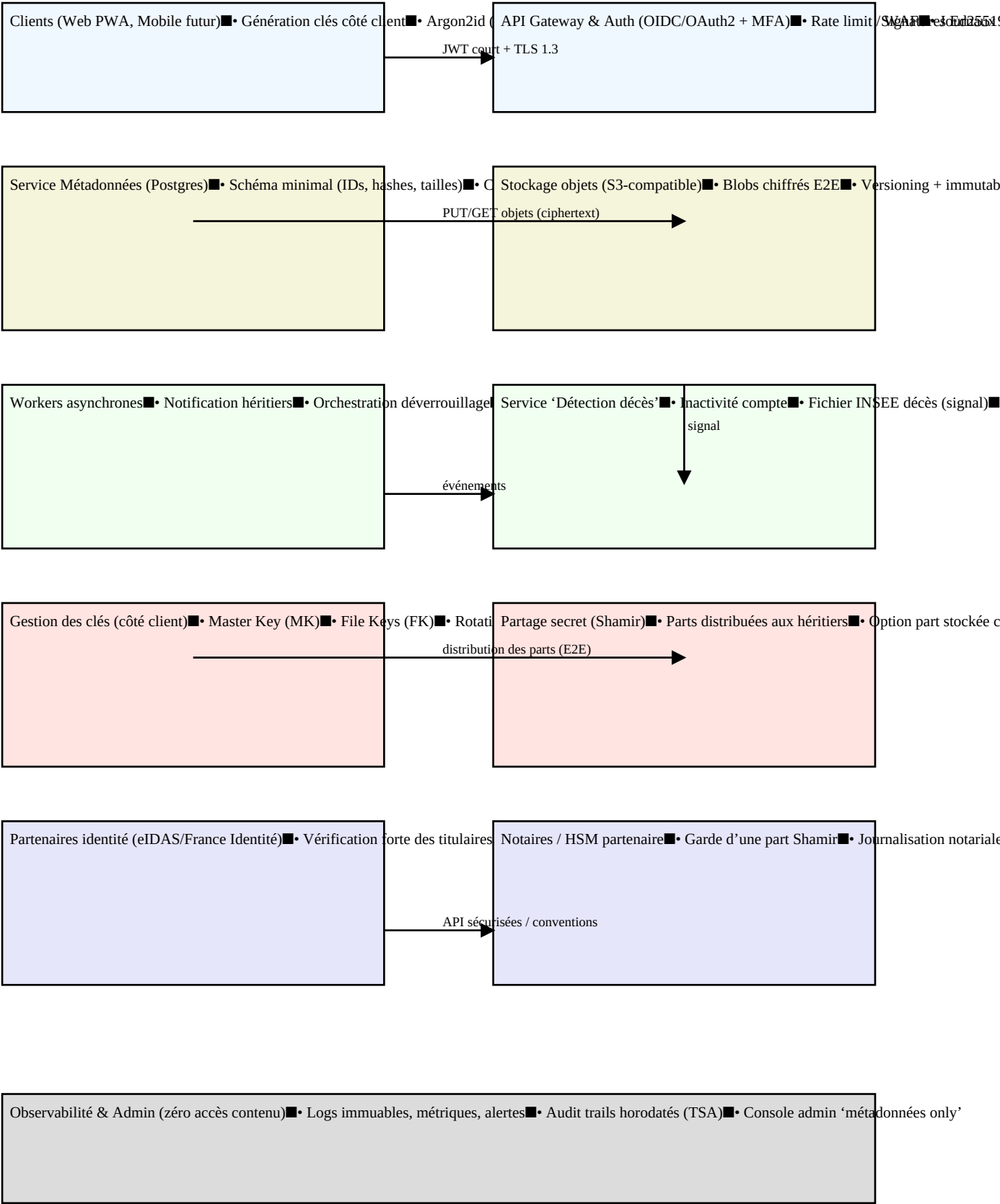


Capsule Numérique Posthume — Architecture backend & sécurité

Schéma global d'architecture (MVP → V1) avec flux chiffrés, gestion des clés et déclenchement post-mortem.



Flux critiques (séquence)

Étape	Description
Inscription	Le client génère une clé maître (MK) localement; dérivation via Argon2id depuis un secret u
Upload	Chaque fichier est chiffré côté client avec une clé fichier (FK) unique; les blobs chiffrés vont
Désignation héritiers	Création des parts Shamir de la clé de déverrouillage; distribution E2E aux héritiers/contact
Détection de décès	Signal = combinaison d'inactivité prolongée + correspondance INSEE + confirmations huma
Déverrouillage	Réunir $\geq k$ parts Shamir → reconstitution de la clé de déchiffrement; remise progressive des
Révocation / Rotation	Le titulaire peut révoquer/rotater la MK; nouvelles parts Shamir émises; anciens liens invalio

Contrôles de sécurité (liste de mise en œuvre)

- Chiffrement bout à bout : WebCrypto/libsodium; aucune clé en clair côté serveur.
- Dérivation : Argon2id (RFC 9106), paramètres élevés, anti-bruteforce + anti-phishing (SRP/PAKE optionnel).
- Auth : OIDC + MFA TOTP/SMS, tokens courts, refresh rotatifs, device binding.
- Transport : TLS 1.3 uniquement, HSTS, CSP stricte, SameSite cookies.
- Stockage : S3 immuable + versioning + réplication multi-région; backups hors-ligne chiffrés.
- Secret sharing : Shamir k/n ; optionalité HSM/notaire pour une part; preuve d'identité forte eIDAS/France Identité.
- Journalisation : logs append-only, horodatage (TSA), détections d'anomalies; conservation selon DPIA.
- Sécu appli : OWASP ASVS 4.0.3, tests SAST/DAST, pentest annuel, bug bounty privé.
- Gouvernance : ISO 27001 (roadmap), DPO externe, DPIA, registre des traitements, politique de rétention/effacement.

Aspects légaux clés (récapitulatif)

- RGPD : non applicable aux personnes décédées (Considérant 27), mais droit FR (art. 85 LIL) encadre les directives post-mortem et l'accès des héritiers.
- Valeur juridique : la capsule ne remplace pas un testament notarié; elle peut contenir des volontés personnelles et des copies; conseiller la formalisation chez notaire.
- Détection de décès : croiser INSEE + validations humaines; établir des CGU précises, un mécanisme de contestation et un registre de preuves.
- Transferts internationaux : privilégier hébergeurs UE (OVH/Scaleway); si tiers US, s'appuyer sur l'EU-US Data Privacy Framework et SCCs si nécessaire.

Pérennité, SRE & Plan de secours

- Objectifs SLO : 99,9% disponibilité API; $RPO \leq 1h$; $RTO \leq 24h$.
- Tests de restauration : mensuels; exercices 'chaos' trimestriels.
- Fin de vie service : procédure d'export universel + déverrouillage anticipé + dépôt notarial/tiers de confiance.
- Assurance : RC pro + cyber; réserve financière pour coûts de conservation ≥ 24 mois sans revenus.